

DPH CLASSIFIEDS

Audit remediation fact check

A corrected update to dphsecuritypatch.pdf,
checked against the current staging
repository and its verification evidence.

ORIGINAL REPORT

2026-09-03

Baseline report: 10 pages

UPDATED REPORT

2026-09-10

Commit: 63a1e629

Scope and standard

This revision fact-checks the claims in the original security and performance patch report against the source tree, tests, Git history, and the current staging commit. A claim is marked confirmed only when current code or a current automated test supports it. Historical live checks are not repeated as current live evidence without a target environment and disposable credentials.

Bottom line

The security response is materially stronger than the original baseline, and the web/mobile product work has advanced substantially. The original report itself needs correction: its Explore virtualization claim is stale, its sessionStorage-cache status is stale, and its backend-size estimate is stale. The highest-value remaining improvements are true list virtualization, least-privilege detail queries, database-enforced dealership scope, responsive image variants, and authenticated live release verification.

Executive summary

The 2026-09-03 report was directionally useful but mixed implementation facts with historical observations. This update separates the two.

Area	Current assessment	Priority
Security controls	CSP, VIN response privacy, deletion cleanup, rate limits, bounded image downloads, malformed-feed shutdown, and signed bridge checks remain supported by source/tests.	Maintained
Explore performance	The old VirtuosoGrid statement is not true at current HEAD. Explore uses a normal responsive grid, IntersectionObserver loading, a 240-item cap, and sessionStorage/in-flight caching.	High
Backend architecture	app.py is 14,165 lines and 61 route modules are present. Extraction and boundary tests progressed, but a large coupled root remains.	Medium
Data privacy	Public VIN and sensitive-field response stripping is tested. The car-detail upstream request still uses select=* before stripping, so least-privilege querying remains open.	High
Release evidence	Current local, Docker, frontend, mobile, and browser simulation gates pass. Protected live/provider verification is not claimed because credentials and a target were not supplied.	Release gate

How to read this report

- Confirmed means the current checkout or current automated tests directly support the statement.
- Stale means the original statement described an older implementation and should not be repeated.
- Open means the issue is still present, only partially addressed, or needs environment-specific proof.

Claim-by-claim audit

Original report claim	Current evidence	Verdict
Explore was fixed with react-virtuoso VirtuosoGrid and useWindowScroll.	Current ExplorePage.jsx explicitly describes a plain responsive grid with an IntersectionObserver sentinel. No Virtuoso import is present. Items are capped at 240 per category.	STALE / OPEN
Explore had no sessionStorage cache.	ExplorePage.jsx reads/writes sessionStorage with a 60-second TTL and maintains an in-flight request map.	STALE - FIXED
Search/filter cursor pagination was implemented.	Backend cursor mapping and listing index routes are present, with route-contract coverage for car, bike, plate, part, and unified listings.	CONFIRMED
VIN privacy was fixed.	test_vin_visibility.py covers anonymous, phone-verified, owner, and admin behavior; car_detail.py strips public fields and removes VIN unless authorized.	CONFIRMED
Homepage preview was narrowed and does not expose VIN.	PUBLIC_CAR_PREVIEW_SELECT is curated; test_homepage_preview_no_vin.py covers the preview boundary.	CONFIRMED
The backend was approximately 25,900 lines.	Current backend/app.py is 14,165 lines, with 61 route Python modules. This is progress, not completion of the monolith reduction.	STALE / OPEN
CSP and the listed security fixes were completed.	vercel.json and application/http_runtime.py set security headers; focused tests cover the relevant contracts. This is repository evidence, not a fresh production penetration test.	CONFIRMED / SCOPE
Hero srcset was not addressed.	No current responsive srcset implementation was found for the hero asset. The broken menu asset was separately corrected to a tracked hero.avif.	OPEN
useStaggeredEntrance was not addressed.	The hook remains used by Explore and multiple list/admin screens, including the current mobile listing cards.	OPEN
Lazy image dimensions and footer content-visibility were acceptable/fixed.	Current web cards reserve image space; hover-footer.jsx still uses contentVisibility: auto. These remain reasonable implementation choices, with real-device profiling still useful.	CONFIRMED / MONITOR
App.js provider tree was left alone.	The app has moved further toward extracted route/runtime boundaries and Expo Router root composition, but broad provider and root coupling remains an architectural follow-up.	OPEN / REFRAME

Key correction

Do not repeat the old virtualization claim

A 240-item cap limits worst-case growth but does not virtualize the DOM. The current implementation improves scroll behavior and memory bounds, yet a large result set can still mount many cards. This should be treated as a performance opportunity, not a completed remediation.

What changed since 2026-09-03

Git history shows a substantial amount of work after the original report. The most important changes are below.

Stream	Observed change since baseline	Impact
Backend boundaries	Health/runtime, identity/listing, public detail, create/update, media, moderation, analytics, dealer, admin lifecycle, recommendations, reports, price history, and other families were extracted into dedicated route modules.	Lower coupling and clearer contract ownership
Backend verification	Route manifest, health boundary, error-contract, extraction-boundary, VIN visibility, and lifecycle tests expanded. Docker API liveness/readiness and worker heartbeat smoke are available.	Stronger regression and release evidence
Web listings	Seller identity flash, URL-backed filter persistence, Explore/Browse filter parity, detail image containment, fullscreen gallery, compact similar listings, and normal window scrolling were addressed.	Improved navigation, privacy presentation, and visual usability
Web Explore	CTA/banner was moved outside the listing scroll region; the current layout uses document/window scrolling and a sentinel for loading.	Removes nested-scroll behavior
Mobile recommendations	Recommendations use an in-memory plus AsyncStorage stale-while-revalidate cache, with background refresh.	Faster repeat visits and better perceived load time
Mobile selling flow	Category cards received layered depth icons; photo selection now supports camera/library permissions, cover guidance, reorder, remove, and larger touch targets.	Higher-fidelity and clearer listing creation
Mobile listing experience	Fullscreen image viewing uses a dark backdrop; My Listings uses responsive window classes and improved layout.	Better focus and foldable/tablet adaptability
Expo platform	The history includes Expo SDK upgrades and native legal/theme/navigation work. Device-specific validation remains separate from TypeScript/Jest validation.	Modernized platform baseline; real-device gate still needed

Current source metrics

Metric	Current value	Evidence
Backend app.py	14,165 lines	wc -l on current staging checkout
Backend route modules	61 Python files	routes/ inventory
Staging revision	63a1e629236078903f2029c93bbf cf72052607c3	HEAD and origin/staging
Explore loading cap	240 items/category	ExplorePage.jsx

Security status

The current security posture is improved, but the original report sometimes described application-level controls as if they were database or deployment guarantees. The distinction matters.

Control	Current state	Residual risk
VIN and sensitive fields	Public response strips protected fields and VIN visibility is authorization-aware; regression tests cover key roles.	Detail fetch still starts from select=*; move to least-privilege selects.
Homepage preview	Curated public select and no-VIN regression test.	Keep the select list explicit as schema evolves.
CSP/security headers	Configured in Vercel headers and runtime HTTP middleware.	Validate the deployed header set on every release.
SSRF/download bounds	URL safety service bounds redirects/download behavior and tests cover the contract.	Provider and egress behavior still needs live validation.
Deletion cleanup	Admin listing deletion includes related lead/report/price-history/verification cleanup, with tests.	Add periodic orphan audit for defense in depth.
Buying-request limits	Rate limiting remains implemented in the dedicated route boundary.	Confirm shared Redis behavior under multi-instance load.
Dealer import safety	Malformed feed rows are tested and auto-disable behavior is covered.	Monitor import failure metrics and alerting.
GitHub bridge	HMAC verification remains part of the protected integration path.	Rotate secrets and verify replay protection in deployment.
Dealership isolation	Some application-level dealership filters exist, but no confirmed database-enforced dealership boundary was found in this audit.	High: enforce RLS/tenant scope at the data layer.
service_role usage	Service-role access remains widespread in backend/app.py and route/runtime dependencies.	High: reduce blast radius with user-scoped tokens and narrow service functions.

Recommended security sequencing

1) Introduce a least-privilege car detail select path with VIN fetched only after authorization. 2) Establish database-level tenant/dealership policies and negative cross-tenant tests. 3) Inventory service_role calls and replace user-facing reads with scoped access where possible. 4) Repeat the authenticated live release lane against the exact deployed revision.

Performance, responsive layout, and platform readiness

The latest product fixes improve perceived speed and responsive behavior, but the evidence supports a pragmatic next set of engineering changes rather than a claim of completion.

Topic	What is now better	Next improvement
Explore loading	SessionStorage TTL cache, in-flight request reuse, cursor/pagination support, 240-item cap, and window scrolling.	Add actual windowed rendering for long feeds; preserve keyboard and screen-reader semantics.
Images	Detail gallery contains images correctly; fullscreen viewing is available; cards reserve image space.	Generate thumbnail tiers and responsive srcset/sizes for bandwidth and LCP.
Search navigation	Filters are represented in the URL and survive listing-to-search navigation.	Add browser matrix coverage for every filter family and deep-link reloads.
Mobile recommendations	Stale-while-revalidate cache improves repeat-load latency.	Measure p50/p95 time-to-first-card on real iOS and Android devices.
Selling photos	Permissions, source selection, cover guidance, reorder, remove, and touch targets improved.	Add upload progress, resumable retry, EXIF orientation normalization, and offline recovery.
Foldables/tablets	Responsive utility defines compact, medium, and expanded window classes; My Listings adapts layout.	Validate hinge-aware posture, split-screen, rotation, safe areas, and keyboard resize on physical devices.
Navigation	Android navbar was brought closer to the iPhone information architecture.	Verify back behavior, deep links, modal dismissal, and accessibility labels on Android 15+ and iOS.
Animations	Existing staggered entrance behavior remains in multiple mobile list surfaces.	Avoid re-running entrance animations on pagination and cap work for reduced-motion users.

Device layout guidance captured for the next release

- Use safe-area insets for top and bottom content, and keep primary actions reachable above the home indicator or gesture area.
- Use fluid constraints and window classes rather than hard-coded phone widths; allow two-column listing layouts only when the expanded window is genuinely wide enough.
- Treat foldable hinge and posture changes as layout events. Recompute columns and image bounds after rotation, resize, or tabletop/book posture changes.
- Keep text blocks readable with a bounded measure, avoid placing critical labels over image crops, and test large text/accessibility font scaling.
- Validate the actual target iOS and Android SDK/device matrix before release; source-level responsive utilities are not a substitute for physical-device evidence.

Additional improvements to carry forward

The report is improved here by recording concrete follow-up work with an owner-ready acceptance condition. These are not presented as already complete.

Priority	Improvement	Acceptance condition
P0	Database-enforced dealership/RLS scope.	A negative test proves a user/dealer cannot read or mutate another dealership's record through any public, dealer, admin, or realtime path.
P0	Least-privilege car detail query.	The public query never selects VIN/protected columns; authorized VIN access is a separate, audited path with response and query tests.
P1	True Explore virtualization.	A long-feed browser test shows a bounded mounted-card count while scrolling and still passes keyboard, focus, and announcement checks.
P1	Responsive image delivery.	Hero and listing images expose correct width descriptors or thumbnail tiers; automated checks verify no oversized source is loaded for small viewports.
P1	Authenticated live release lane.	Public and protected Playwright smoke suites pass against the exact deployed revision, with disposable credentials injected only through the environment.
P2	Upload resilience.	Photo uploads show progress and retry, recover from transient failures, preserve order, and normalize orientation.
P2	Provider and operations proof.	Redis, email/SMS/OCR/storage, alerts, and deployment headers are tested in their real staging configuration.

Release gate matrix

Lane	Current result	Interpretation
Backend pytest	1346 passed, 9 skipped, 75 warnings, 20 subtests	Local backend gate passed
Docker API smoke	Passed liveness/readiness/404/401	Container API contract passed
Worker smoke	Passed health plus Redis heartbeat	Worker composition contract passed
Frontend Jest/build	172 tests passed; production build passed	Web unit and build gates passed
Bundle/media	104.8 KiB main; 1320.3 KiB largest JS; 31 images clean	Within current policy
Public browser	75 passed, 27 protected skipped	Responsive public lane passed; auth lane not run
Local browser simulation	27 passed	Real React flows with page-local API simulator
Mobile TypeScript/Jest	TypeScript passed; 264 tests passed	Static and unit gates passed
Live release/provider	Not claimed in this update	Requires target URL and disposable credentials

Methodology and final status

The audit was performed from the current checkout on 2026-09-10. It used repository source inspection, focused test evidence, the full local verification results recorded for the staging work, and Git history after the original PDF's 2026-09-03 baseline.

Evidence type	Used for
Current source	Checking route boundaries, response privacy, cache behavior, scroll model, image handling, mobile flows, and remaining implementation markers.
Current tests	Checking security contracts, route manifests, backend behavior, Docker health, web/mobile tests, responsive browser flows, and local simulation.
Git history	Identifying changes after the original report and avoiding attribution of newer fixes to the 2026-09-03 baseline.
Not used as current proof	The original PDF's historical live URLs, provider checks, and credential-dependent assertions were not re-presented as current live evidence.

Document status

Updated and fact-checked against staging commit 63a1e629236078903f2029c93bbfcf72052607c3 on 2026-09-10. The PDF now labels stale claims, preserves confirmed security controls, records the latest web/mobile/backend changes, and gives explicit next gates for the remaining security and performance work.

Prepared for engineering and release review
Repository: /Users/suhayl/Downloads/Flask-React-superbase-classified | Branch: staging | Revision: 63a1e629